Application security review

Workshop Prep Agent - scoped review sample

Prepared 22 October 2026 | Fix verification

Reviewer: Farouk Hajjej

1. Executive summary

The review identified a low-severity resource-handling weakness in the request reader used by Workshop Prep Agent. Oversized input was rejected only after its entire body had been read. The published fix stops consumption earlier and preserves valid JSON handling. A local verification of the frozen before/fix readers reproduced that improvement on October 22. Production availability impact and agent-specific security controls were not assessed.

Recorded results: 1 finding; 0 confirmed open, 0 unresolved, 1 fixed and 0 dismissed.

2. Scope and method

Review coverage	Recorded scope
Reviewed files	1
Deferred / skipped files	0 / 0
Coverage status	Limited review; see assessment boundaries below
Review method	Fix verification; evidence and verification are described below.

Declared scope and limitations

Own-product Workshop Prep Agent example, not an independent audit or client engagement. This report addresses one shared JSON reader, not the whole app.

Original ChatNoir-guided source review: October 16, 2026, using ChatNoir 0.1.2. The report data is now represented with the current 0.2.3 helper format.

Fresh local verification: October 22, 2026. A separate script extracted the original origin check, body reader and error class from each frozen revision, transpiled them with esbuild and called them in process. It did not execute the full Next.js route or a deployed endpoint.

The historical owner record reports 24 focused tests, TypeScript checks and a production build passing on October 16. These checks were not rerun for this example.

Prompt injection, model behavior, tool permissions, secrets, customer isolation, concurrent load, effective upstream limits and production availability were outside this verification.

Source assessment: https://github.com/fhajjej-ship-it/ChatNoir/blob/main/docs/separate-app-evaluation.md

Conclusions apply only to the recorded scope and evidence. No overall application security grade is assigned. This document presents supplied review results; generating it performs no additional testing.

3. Detailed findings

WPA-01: Request size checked after full-body read

Fix verified within stated scope | Severity: Low | Evidence confidence: High

Source location: lib/http.ts:19

Classification: CWE-400

Evidence

1. The original revision 83daa0c5befb6ae6c7a2184fdb9aa6438d7da0a6 awaited request.text() before checking the body length.

2. The fresh October 22 local replay supplied 1,048,576 ASCII bytes in 16,384-byte chunks with a 250,000-character limit. The original reader consumed the entire stream and threw error 413 without cancellation.

3. The fixed reader at 6fbd0bd5790d10305b6c70e02f1d14eb0764ef68 consumed 262,144 bytes, cancelled the remainder and threw error 413. Small valid JSON returned the expected object in both revisions.

Failure path and impact

1. A producer supplies an oversized body to the shared reader, with a matching Origin header in the local probe.

2. Whole-body decoding before size validation consumes the body before the application can reject it.

3. This creates avoidable buffering and possible resource pressure under load. The replay establishes consumption behavior, not a production denial of service.

Controls and limits on impact

1. Both revisions reject oversized input with error 413. This is a resource-consumption weakness, not a demonstrated input-limit bypass into agent execution.

2. Effective deployed limits, remote reachability and service disruption were not established. Severity remains low.

3. The 75% lower byte count applies to this exact probe; it is not an allocated-memory or latency benchmark. The input limit remains character-based.

Recommended remedy

Read and decode the stream incrementally, cancel it as soon as the existing character limit is crossed, retain final length and JSON checks, and release the reader lock. The published fix implements this behavior; it does not add an agent authorization boundary.

4. Verification and remaining work

WPA-01: Fix verified within stated scope

Verification method: Executed local test

Verified locally on October 22, 2026. The original reader consumed the full 1,048,576-byte request before rejecting it. The fixed reader stopped at 262,144 bytes and cancelled the remainder. Both rejected oversized input with status 413 and accepted the small valid JSON control. Reviewed source digests matched the replay receipt. Only extracted reader and supporting functions were executed. The earlier full-route and 24-test results are historical evidence from October 16 and were not rerun.

The recorded verification supports this fix only within the stated test conditions. Deployment and broader security coverage require separate confirmation.

Evidence reference

The identifiers below bind these results to the reviewed source snapshot. They support reproduction and do not establish assessment completeness.

Report data version: ChatNoir 0.2.3

Source inventory SHA-256: 4f0f5349d5d255f7443f23e79d82acb3fcf85b7279a0b2f4807f03ffc2504996

Recorded Git revision: 6fbd0bd5790d10305b6c70e02f1d14eb0764ef68

Source checkout: No uncommitted changes recorded

lib/http.ts | 2591 bytes | SHA-256 301da82a84705b336137408f7060eac3b5215a8de1eddde986a88c324d774e89

This is a point-in-time, scoped review record, not a security certification. Review confidential report contents before sharing.